

Guía Metodológica de la Encuesta PILAR-ENS

Cómo pasar de una colección de respuestas más o menos sinceras a un mapa razonable de madurez, riesgo y cumplimiento ENS apoyado en PILAR.

1. Objetivo y alcance

Esta guía explica cómo usar la encuesta integral para:

- Evaluar el grado de adopción de una metodología de análisis de riesgos alineada con PILAR y el ENS.
- Medir la madurez de la implementación de salvaguardas y controles (L0-L5).
- Construir un Índice Global de Madurez (IGM) y preparar insumos para estimar el ROI de las inversiones en seguridad y cumplimiento ENS.

La encuesta está diseñada para ser aplicada tanto a nivel de organización como, si se desea, por sistema de información o dominio de seguridad.

2. Población objetivo y roles

Se recomienda que la encuesta no sea rellenada por una única persona omnisciente (especie en peligro de extinción), sino por un pequeño grupo representativo:

- Responsables de seguridad / ENS.
- Responsables de TI / infraestructuras.
- Responsables de negocio / propietarios de procesos clave.
- En organizaciones grandes, representantes de continuidad de negocio y auditoría interna.

La respuesta puede coordinarse en una sesión conjunta o mediante recopilación previa seguida de consolidación.

3. Escalas de respuesta y correspondencia con niveles de madurez

Las preguntas utilizan principalmente escalas ordinales (de “no existe” a “muy formalizado”) que deben traducirse a valores numéricos para el cálculo del IGM y otros indicadores.

3.1 Escala de madurez L0-L5

Cuando la pregunta se refiere explícitamente a madurez de salvaguardas o procesos, se recomienda mapear las respuestas a:

- L0: inexistente (0 %)
- L1: ad hoc / informal (10 %)
- L2: reproducible intuitivo (50 %)
- L3: proceso definido (80 %)
- L4: gestionado y medible (90 %)
- L5: optimizado (100 %)

Esta escala deriva de las descripciones habituales en PILAR y en las guías ENS sobre índices de madurez. [web:16][web:17][web:20][web:23]

3.2 Escalas cualitativas (bajo, medio, alto)

Para preguntas de tipo “nivel de comprensión percibido”, “coherencia” u otras valoraciones cualitativas, se propone una escala 1–5:

- 1: muy bajo
- 2: bajo
- 3: medio
- 4: alto
- 5: muy alto

Estas se utilizarán como factores de ajuste o como indicadores complementarios.

4. Cálculo del Índice Global de Madurez (IGM)

El IGM pretende ofrecer un valor agregado entre 0 y 100 que resuma el estado de madurez de la organización en relación con:

- Metodología de análisis de riesgos.
- Modelado de activos y dependencias.
- Madurez de salvaguardas y controles.
- Ciclo de vida y continuidad de negocio.
- Cultura, recursos y gobierno.

4.1 Dimensiones propuestas

Se proponen cinco dimensiones, cada una con ponderación inicial del 20 % (ajutable según contexto):

1. Metodología y alcance del análisis de riesgos.
2. Modelado de activos, dominios y dependencias.
3. Madurez de salvaguardas y controles ENS.
4. Integración en ciclo de vida, continuidad y métricas.
5. Cultura, recursos y gobierno.

Cada dimensión se calcula como media ponderada de un subconjunto de preguntas de la encuesta.

4.2 Ejemplo de asignación de preguntas a dimensiones

- Dimensión 1: preguntas 2.1–2.4, 4.1–4.4.
- Dimensión 2: preguntas 3.1–3.5.
- Dimensión 3: preguntas 5.1–5.5, 6.1–6.5.
- Dimensión 4: preguntas 7.1–7.4, 8.1–8.4, 9.1–9.5.
- Dimensión 5: preguntas 1.4, 10.1–10.3, 11.1.

Cada pregunta se mapea a un valor 0–100 utilizando la escala correspondiente (L0–L5, 1–5, etc.).

4.3 Fórmula genérica

Sea (D_i) el valor de la dimensión (i) (0–100) y (w_i) su peso (por defecto, ($w_i = 0\{, \}2$)).

El IGM se define como:

$$\left[\begin{array}{l} \text{IGM} = \sum_{i=1}^5 w_i \cdot D_i \\ \end{array} \right]$$

Los pesos pueden ajustarse para reflejar prioridades estratégicas (por ejemplo, dar mayor peso a la madurez de medidas ENS en fases iniciales de adecuación).

5. Uso de la encuesta con proyectos PILAR y perfil ENS

5.1 Sincronización con proyectos existentes

Si la organización ya dispone de proyectos PILAR con perfil ENS:

- Utilizar la encuesta para contrastar la percepción declarada con los índices de madurez que la propia herramienta puede calcular. [web:17][web:20]
- Identificar divergencias (por ejemplo, alta madurez percibida versus madurez baja en controles críticos).

5.2 Organización sin PILAR pero con ENS

Si no se usa PILAR, la encuesta sigue siendo útil para:

- Diagnosticar el nivel de formalización del análisis de riesgos.
- Identificar carencias en modelado de activos, dependencias y zonas.
- Establecer una línea base antes de adoptar una herramienta especializada.

6. Estimación del ROI en seguridad y ENS

La encuesta no pretende producir un ROI automático (la alquimia tiene límites), pero proporciona insumos esenciales:

- Información sobre el grado de implantación de medidas.
- Datos sobre integración con continuidad y respuesta a incidentes.
- Indicadores sobre cultura y soporte directivo.

Combinando el IGM con datos de incidentes (frecuencia, impacto) y de inversión (OPEX/CAPEX) se puede:

- Estimar la reducción de riesgo (pérdida esperada) asociada a mejoras de madurez.
- Priorizar inversiones según el aumento esperado del IGM en dimensiones concretas.

Se sugiere utilizar la plantilla de Excel adjunta para consolidar métricas, modelar escenarios de inversión y obtener valores comparables de ROI.

7. Recomendaciones de aplicación

- Aplique la encuesta al menos una vez al año, idealmente antes de la revisión ENS.
- No la utilice como arma arrojadiza: su valor está en la sinceridad de las respuestas.
- Documente las decisiones de ponderación y las reglas de cálculo del IGM para permitir comparaciones año a año.
- Considere realizar la encuesta también a nivel de sistema crítico, para comparar madurez entre ámbitos.

8. Limitaciones y advertencias

- El IGM es un indicador agregado: útil para navegar, no para sustituir el detalle del análisis de riesgos.
- Comparaciones entre organizaciones deben hacerse con cautela, asegurando escalas y criterios homogéneos.
- Una puntuación alta de madurez no garantiza ausencia de incidentes; sí debería correlacionarse con mejor capacidad de gestión.

La guía puede ampliarse con anexos específicos por sector (sanidad, educación, administración local, etc.), adaptando pesos y ejemplos sin alterar la estructura básica.